付録B
Web APIチェックリスト

最後に本書の内容を簡単に確認するためのチェックリストを用意しました。Web API開発時のチェックにお役立てください。

- ☐ URIが短く入力しやすくなっているか
- ☐ URIが人間が読んで理解できるようになっているか
- ☐ URIが小文字のみで構成されているか
- ☐ URIが改造しやすくなっているか
- ☐ URIにサーバ側のアーキテクチャが反映されていないか
- ☐ URIのルールは統一されているか
- ☐ 適切なHTTPメソッドを利用しているか
- ☐ URIで利用する単語は多くのAPIで同じ意味に利用されているものを選んでいるか
- ☐ URIで使われている名詞は複数形になっているか
- ☐ URI中にスペースやエンコードを必要とする文字が入っていないか
- ☐ URI中の単語はハイフンでつないでいるか
- ☐ ページネーションは適切に設計されているか
- ☐ ログインにはOAuth 2.0を利用しているか
- ☐ レスポンスのデータ形式はJSONがデフォルトになっているか
- ☐ データ形式の指定にはクエリパラメータを使う方法をサポートしているか
- ☐ 不要なJSONPに対応していないか
- ☐ レスポンスのデータ内容はクライアントから指定できるようになっているか
- ☐ レスポンスデータに不要なエンベロープが入っていないか
- ☐ レスポンスデータの構造は可能なかぎりフラットになっているか
- ☐ レスポンスデータが配列ではなくオブジェクトになっているか
- ☐ レスポンスのデータ名として多くのAPIで同じ意味に利用されている一般的な単語を選んでいるか
- ☐ レスポンスのデータ名はなるべく少ない単語数で表現しているか

- ☐ レスポンスのデータ名として複数の単語を連結する場合、その連結方法はAPI全体を通して統一してあるか
- ☐ レスポンスのデータ名として変な省略形を使用していないか
- ☐ レスポンスのデータ名の単数形／複数形はデータの内容と合っているか
- ☐ エラー時のレスポンスはクライアントが原因を切り分けられるような情報を含んでいるか
- ☐ エラーの際にHTMLが返っていないか
- ☐ 適切なステータスコードが返るようになっているか
- ☐ メンテナンス時には503を返すようになっているか
- ☐ 適切なメディアタイプを返しているか
- ☐ 必要な場合はCORSに対応しているか
- ☐ クライアントが適切にキャッシュを行えるように`Cache-Control`、`ETag`、`Last-Modified`、`Vary`などのレスポンスヘッダを返しているか
- ☐ キャッシュをさせたくないデータには`Cache-Control: no-cache`が付けられているか
- ☐ APIはバージョンで管理されているか
- ☐ APIのバージョンはセマンティックバージョニングに沿ったものになっているか
- ☐ メジャーバージョン番号がURIに入っており、ひと目でわかるようになっているか
- ☐ APIの提供を終了する際のことを考慮に入れているか
- ☐ APIの最低提供期間をドキュメントに明記しているか
- ☐ HTTPSでAPIを提供しているか
- ☐ JSONのエスケープをきちんと行っているか
- ☐ JSONは`X-Requested-With`ヘッダを認識するなど、`SCRIPT`要素では読み込めないようになっているか
- ☐ ブラウザからアクセスさせるAPIではXSRFトークンを利用しているか
- ☐ APIが受け取るパラメータはきちんと不正値（マイナスの値など）をチェックしているか
- ☐ リクエストが再送信されてもデータを再度更新してしまわないようになっているか
- ☐ レスポンスにセキュリティ対策用の各種ヘッダをきちんと付けているか
- ☐ レートリミットによる制限を行っているか
- ☐ レートリミットの制限回数は想定されるユースケースに対して少なすぎないか